

MaquiVelo

Auditoria completa: funcionalidade, segurança, UI/UX, acessibilidade, performance, código e prontidão para produção

Estado de deploy

Precisa de confirmação



Projeto	Catálogo de máquinas de costura com backoffice (Laravel 12)
Repositório	github.com/ricardoVelo2424/maquivelosoV2
Commit auditado	86bad95 · branch main (= origin/main)
Auditor	Claude Code (Claude Opus 5.5)
Alterações ao projeto	Nenhuma. Só foram criados os dois relatórios em docs/audit/

Índice

2. Resumo executivo	3
3. Estado geral	4
4. Métricas	4
5. Achados P0 e P1	6
5.1 P0 — bloqueadores	6
5.2 P1 — antes do lançamento	6
6. Achados P2 e P3	11
6.1 P2 — primeiras semanas	11
6.2 P3 — melhorias	18
7. Funcionalidades e lógica	26
8. Segurança	28
9. UI/UX e responsividade	29
10. Acessibilidade	30
11. Performance	30
12. Qualidade de código	31
13. Base de dados	31
14. Testes	32
15. SEO e privacidade	32
16. Deploy readiness	34
17. Funcionalidades em falta	34
18. Plano de ação	36
19. Conclusão	38

2. Resumo executivo

Precisa de confirmação

Sem bloqueadores técnicos (0 × P0). O deploy é tecnicamente possível, mas o lançamento público deve esperar pelos seis achados P1 (≈3 dias de trabalho) e por três decisões do dono: fornecedor de email, limites de upload e memória do alojamento, e validação jurídica das páginas legais.

0

P0

6

P1

17

P2

26

P3

49

total

Maior risco

As fotos tiradas na vertical com o telemóvel aparecem de lado no catálogo, na página inicial e no backoffice (**FUNC-001**). Acresce que, com os limites por omissão do PHP e do Nginx documentado, o próprio upload dessas fotos falha (**DEPLOY-001**). O fluxo principal do negócio, fotografar a máquina e publicá-la, fica afetado pelos dois lados.

Achados P1 a fechar antes do lançamento

1. **SEC-001** — Dependências PHP de produção com advisories publicados
2. **FUNC-001** — Miniaturas ignoram a orientação EXIF (fotos verticais aparecem de lado)
3. **FUNC-002** — Recuperação de password não entrega email com a configuração de produção documentada
4. **DEPLOY-001** — Limites de upload do servidor não documentados e incompatíveis com o formulário
5. **UI-001** — Backoffice sem layout responsivo
6. **PERF-001** — Logótipo de 1,17 MB carregado em todas as páginas

Resolvido desde a auditoria anterior (41f699d)

- Credenciais de administrador por omissão: existe `admin:create` e os seeders não correm em produção (testado em `ProductionSafetyTest`).
- Registo público desligado (`GET/POST /register` → 404).
- Existem `DEPLOYMENT.md` e `.env.production.example` com HTTPS, permissões, backups e rollback.
- Miniaturas GD: o catálogo passou de ≈46 MB de imagens para ≈2,6 MB por página.
- Regras de preço centralizadas (`Machine::priceState()` + componente `x-machine.price`); preço aceita vírgula (`PriceNormalizer`).
- Escolha da imagem principal (transação e bindings com scope → 404 entre máquinas).
- Mensagens flash no backoffice, identidade visual, menu mobile, skip link, reduced-motion, labels no catálogo, galeria com lightbox, breadcrumb, página de contacto honesta.
- Código morto, aliases antigos e axios removidos; `.gitignore` cobre sqlite e `.claude`.

Âmbito e método

Auditoria externa ao commit 86bad95 (main = origin/main, 30/09/2026) sem qualquer alteração ao projeto. Os testes funcionais correram num clone isolado com SQLite, servidor PHP (memory_limit 128M) e 20 máquinas criadas pelo formulário real do backoffice. As fotos de teste incluíam fotos de 12 MP, uma foto com orientação EXIF, uma com GPS e uma de 48 MP. A interface foi capturada com Chrome real em 375, 390, 768, 1024 e 1440 px, e a acessibilidade verificada com axe-core 4.13.0. Cada achado indica se está *Confirmado* (reproduzido ou medido), é *Provável* (dedução direta do código) ou *Não confirmado*.

3. Estado geral

Estados possíveis: Bom · Atenção · Precisa de correção · Bloqueador. Nenhuma área está em Bloqueador.

Área	Estado	Observação
Funcionalidade	Atenção	Fluxos completos. Miniaturas rodadas (FUNC-001), recuperação de password inoperante em produção (FUNC-002)
Regras de preço	Atenção	Os 4 casos estão corretos. Valor arredondado às unidades e "0 €" (FUNC-006)
Segurança	Atenção	Controlos base corretos. Dependências com advisories high (SEC-001), sem cabeçalhos de segurança (SEC-002)
UI pública	Bom	Sem overflow de 375 a 1440 px, CLS 0. Conteúdo invisível sem JS (UI-002)
UI backoffice	Precisa de correção	Scroll horizontal em todas as páginas a 375/390 px; na lista de máquinas também a 768 e 1024 px (UI-001)
Acessibilidade	Atenção	Campos sem label no backoffice, foco da lightbox, contraste do CTA WhatsApp
Performance	Precisa de correção	Logótipo de 1,17 MB em todas as páginas (PERF-001); detalhe ≈6,8 MB (PERF-002)
Arquitetura/código	Bom	Serviço e config centralizados. Restos do skeleton, BOM, JS inline
Base de dados	Bom	Índices e FKs adequados. MariaDB por reconfirmar nesta versão
Testes	Bom	98 passam. Não cobrem os defeitos encontrados
Dependências	Precisa de correção	12 advisories high em produção, resolvíveis com <code>composer update</code>
SEO	Atenção	Título igual em todas as páginas, sem OG, sem sitemap
Privacidade/legal	Atenção	GPS nos originais públicos; faltam páginas legais (Requer validação jurídica)
Deploy	Atenção	Boa documentação; email e limites de upload por definir

4. Métricas

Achados por prioridade

P0	0
P1	6
P2	17
P3	26

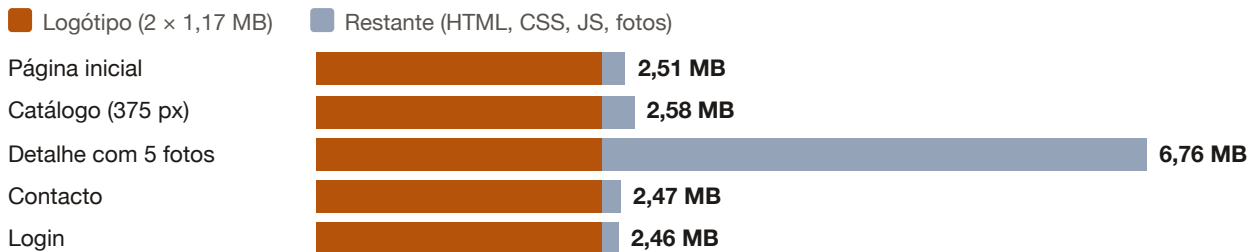
Qualidade e build

Métrica	Valor
<code>php artisan test</code> (com build Vite)	98 passam · 1 ignorado · 273 asserções · 2,08 s
<code>php artisan test</code> (sem <code>public/build</code>)	27 falham · 71 passam · 1 ignorado (TEST-001)
Build Vite	CSS 67,79 kB (11,51 kB gzip) · JS 45,82 kB (16,53 kB gzip)

Métrica	Valor
Rotas / migrations	48 rotas (4 da Livewire) · 10 migrations
<code>composer validate --strict</code>	Válido
<code>composer audit --no-dev</code>	41 advisories em 14 pacotes: 12 high · 25 medium · 3 low · 1 sem severidade
<code>composer audit (total)</code>	45 advisories em 16 pacotes: 13 high · 25 medium · 6 low · 1 sem severidade
<code>npm audit --omit=dev /total</code>	0 / 10 (2 critical · 6 high · 1 moderate · 1 low, todas de desenvolvimento)

Peso da primeira visita

Medido no Chrome contra o servidor de teste, sem compressão nem cache. O logótipo foi descarregado duas vezes (imagem e favicon).



Base de dados e interface

Métrica	Valor
Queries SQL por página	Página inicial 14 · catálogo 10 · detalhe 7 · contacto 4 · sem N+1
Overflow horizontal no site público	Nenhum em 375 / 390 / 768 / 1024 / 1440 px
Overflow no backoffice a 375 px	Todas as páginas (lista de máquinas: 1156 px); também a 768 e 1024 px na lista (1188 px)
CLS	0 em todas as páginas e larguras
Pedidos externos	0 no site público; 1 (fonts.bunny.net) no login e no perfil
Alvos de toque < 24 px	3 a 12 por página pública
Memória do GD por imagem	base 22 MB · 24 MP 120 MB · 48 MP 214 MB (falha com 128M)

5. Achados P0 e P1

Cada achado indica o estado atual, o problema, o impacto, a evidência, os ficheiros e linhas, a recomendação, o esforço e se bloqueia o deploy. O ID da tarefa liga ao plano de ação (secção 18).

5.1 P0 — bloqueadores

Nenhum achado P0 confirmado. Não há bloqueadores técnicos ao deploy.

5.2 P1 — antes do lançamento

P1 SEC-001 — Dependências PHP de produção com advisories publicados

Confiança Confirmado (advisories); Provável risco de exploração baixo

Bloqueia deploy Não (corrigir antes do lançamento)

Esforço 1–2 h

Tarefa T01

Estado atual	O <code>composer.lock</code> fixa laravel/framework v12.48.1, symfony/mime v7.4.0, league/commonmark 2.8.0, guzzlehttp/guzzle 7.10.0 e livewire/livewire v4.0.2.
Problema	<code>composer audit --no-dev</code> reporta 41 advisories em 14 pacotes (12 high). Os high são: - laravel/framework: "CRLF injection in default email rule" (PKSA-3r5d-mb8f-1qw9, versões < 12.60.0). - symfony/mime: CVE-2026-45067, injeção de cabeçalhos de email/SMTP via CRLF. - guzzlehttp/guzzle: CVE-2026-69246. - symfony/http-kernel: CVE-2026-45075. - league/commonmark: 8 advisories (DoS e bypass de filtro XSS).
Impacto	Nesta app a exploração é limitada. Não há Markdown renderizado nem pedidos HTTP de saída. A regra <code>email</code> é usada em login, perfil, definições e recuperação de password, e o único email enviado é o de reposição. Mesmo assim, não se justifica lançar com o framework 21 versões patch atrás e advisories high públicos, quando a correção é trivial.
Evidência	<code>composer audit --no-dev --format=json</code> . O <code>composer update --dry-run</code> no clone resolve para laravel/framework 12.69.3, symfony/mime 7.4.19, league/commonmark 2.10.3, guzzle 7.15.5 e livewire 4.4.7, sem mexer nas constraints.
Ficheiros	<code>composer.lock</code> ; <code>composer.json:12</code>
Recomendação	Correr <code>composer update</code> num branch, depois <code>npm run build && php artisan test</code> , e fazer commit do lock. Acrescentar <code>composer audit --no-dev</code> ao <code>.github/workflows/tests.yml</code> .

P1 FUNC-001 — Miniaturas ignoram a orientação EXIF (fotos verticais aparecem de lado)

Confiança Confirmado

Bloqueia deploy Não (corrigir antes do lançamento)

Esforço 2–3 h

Tarefa T02

Estado atual	<code>ThumbnailService::generate()</code> usa <code>imagecreatefromjpeg</code> e <code>imagecopyresampled</code> . O GD não aplica a tag Orientation e a miniatura JPEG é gravada sem EXIF.
Problema	Os telemóveis gravam as fotos verticais com píxeis em paisagem e Orientation=6 ou 8. O browser roda o original, mas a miniatura fica deitada.
Impacto	As fotos ficam rodadas 90° nos cartões do catálogo, nos destaques da página inicial, na lista e no formulário do backoffice. Afeta o fluxo de upload mais provável (fotos de telemóvel). O dono vê a foto correta no detalhe e rodada na lista, sem perceber porquê.

Evidência A fixture `rotated.jpg` (2400×1800, Orientation=6) foi enviada pelo formulário real (máquina 8, "Pfaff Hobbylock 2.0"). A miniatura gerada tem 600×450, sem EXIF. O cartão do catálogo mostra a seta a apontar para a esquerda; o detalhe mostra-a a apontar para cima (figura 1).

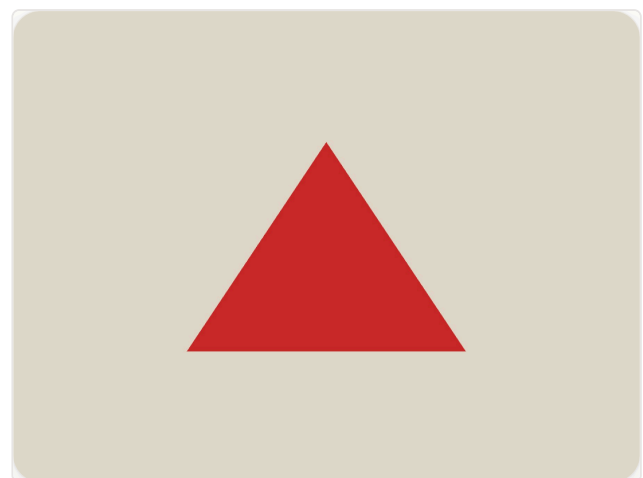
Ficheiros `app/Services/ThumbnailService.php:43-74`;
`app/Http/Controllers/Admin/MachineController.php:137-146`

Recomendação

- Em JPEG, ler `@exif_read_data($fullPath)['Orientation']` e aplicar `imagerotate / imageflip` (casos 2–8) antes de redimensionar, trocando largura e altura nos casos 5–8.
- Juntar `exif` às extensões exigidas em `DEPLOYMENT.md`.
- Criar um teste com fixture Orientation=6.
- Depois do deploy, correr `php artisan machines:generate-thumbnails --force`.



Cartão do catálogo (miniatura GD): seta para a esquerda, barra à esquerda



Página de detalhe (original): seta para cima, orientação correta

Figura 1 — A mesma foto (Orientation=6) no catálogo e no detalhe da máquina 8, a 1024 px.

P1 FUNC-002 — Recuperação de password não entrega email com a configuração de produção documentada

Confiança Confirmado **Bloqueia deploy** Precisa de confirmação (decisão: SMTP sim/não)

Esforço 3–4 h, mais a escolha do fornecedor SMTP **Tarefa** T03

Estado atual

- `.env.production.example:64` define `MAIL_MAILER=log` e `:25` define `LOG_LEVEL=warning`.
- `DEPLOYMENT.md:49-52` e `:296` afirmam que a app não envia email.
- `admin:create` não atua sobre um admin existente ("já é administrador. Nada a fazer.").

Problema `/forgot-password` continua ativo e responde "We have emailed your password reset link.". Com o mailer `log`, o email é escrito no log ao nível debug, que `LOG_LEVEL=warning` descarta. Nada é enviado nem guardado.

Impacto	- Se o único administrador esquecer a password, só consegue voltar a entrar com acesso SSH e tinker/SQL. - A mensagem de sucesso engana. - Em local, os links de reposição ficam no <code>laravel.log</code> (4 ocorrências no clone). É aceitável em dev, mas mostra que o fluxo depende do log.
Evidência	Pedido real ao clone com a mensagem de sucesso. O <code>LogTransport</code> do framework regista ao nível <code>debug</code> (vendedor/laravel/framework/src/Illuminate/Mail/Transport/LogTransport.php:54). <code>CreateAdminUser.php:49-53</code> .
Ficheiros	<code>.env.production.example:25,64</code> ; <code>DEPLOYMENT.md:49-52,296</code> ; <code>app/Console/Commands/CreateAdminUser.php:49-53</code> ; <code>routes/auth.php:23-27</code>
Recomendação	(a) Configurar SMTP transacional em produção, documentá-lo em <code>DEPLOYMENT.md</code> e em <code>.env.production.example</code>, e corrigir a frase "no outbound email". (b) Criar <code>php artisan admin:reset-password {email}</code>, ou uma opção <code>--reset-password</code> em <code>admin:create</code>. (c) Enquanto não houver SMTP, esconder o link "Forgot your password?".

P1 DEPLOY-001 — Limites de upload do servidor não documentados e incompatíveis com o formulário

Confiança Confirmado (configuração); Provável (413 não reproduzido com Nginx real)

Bloqueia deploy Precisa de confirmação (valores do alojamento) **Esforço** 1-2 h **Tarefa** T04

Estado atual	O backoffice aceita até 8 imagens de 5 MB por pedido (<code>images max:8</code> , <code>images.* max:5120</code> , até 40 MB). <code>DEPLOYMENT.md:232</code> define <code>client_max_body_size 8M</code> e o documento não menciona <code>upload_max_filesize</code> , <code>post_max_size</code> nem <code>memory_limit</code> .
Problema	- Com os valores por omissão do PHP (<code>upload_max_filesize=2M</code>, <code>post_max_size=8M</code>), uma foto típica de telemóvel (3-5 MB) é rejeitada. - Com o Nginx documentado, duas fotos de 4,2 MB (8,4 MB) já dão 413 antes de o Laravel responder.
Impacto	O dono não consegue carregar várias fotos de uma vez. O 413 aparece como página de erro genérica do Nginx, sem mensagem da app.
Evidência	<code>DEPLOYMENT.md:232</code> ; o grep não encontra <code>upload_max_filesize</code> , <code>post_max_size</code> nem <code>memory_limit</code> ; as fotos de teste 4032×3024 têm ≈4,2 MB cada.
Ficheiros	<code>DEPLOYMENT.md:232</code> e §2/§7; <code>app/Http/Controllers/Admin/MachineController.php:175-177</code>
Recomendação	- Documentar e configurar <code>upload_max_filesize=6M</code>, <code>post_max_size=48M</code>, <code>max_file_uploads=20</code>, <code>memory_limit=256M</code> (ver FUNC-003) e <code>client_max_body_size 48M</code>. Em alternativa, baixar o limite por pedido para caber no alojamento. - Mostrar na UI o limite total por envio.

P1 UI-001 — Backoffice sem layout responsivo

Confiança Confirmado **Bloqueia deploy** Não **Esforço** 1–1,5 dias **Tarefa** T05

Estado atual `layouts/admin.blade.php:17` tem a barra lateral `w-72` (288 px) sempre visível e `:103` tem `<main class="relative z-10 flex-1">` sem `min-w-0`. A tabela da lista de máquinas não se adapta (precisa de ≈ 900 px além da barra lateral).

Problema A 375 px sobram 87 px para o conteúdo e todas as páginas do backoffice ganham scroll horizontal (o perfil Breeze é a exceção). A lista de máquinas precisa de 1188 px e transborda também a 768 e 1024 px. A 1440 px não há problemas.

Impacto Gerir pelo telemóvel ou tablet é impraticável, e é o cenário natural para fotografar e publicar uma máquina.

Evidência ScrollWidth medido:

Página	Largura	scrollWidth
Dashboard	375	419 px
Lista de máquinas	375 / 390	1156 px
Lista de máquinas	768 / 1024	1188 px
Categorias	375	554 px
Criar / editar	375	426 px
Definições	375	409 px
Show	375	543 px

Ver figura 2.

Ficheiros `resources/views/layouts/admin.blade.php:17,103` ;
`resources/views/admin/machines/index.blade.php`

- Recomendação**
- Barra lateral off-canvas abaixo de `lg`, com Alpine (já carregado) e botão de menu.
 - `min-w-0` no `main`.
 - Lista de máquinas em cartões abaixo de `md`, ou `overflow-x-auto` no contentor da tabela.
 - Validar a 375, 768 e 1024 px.

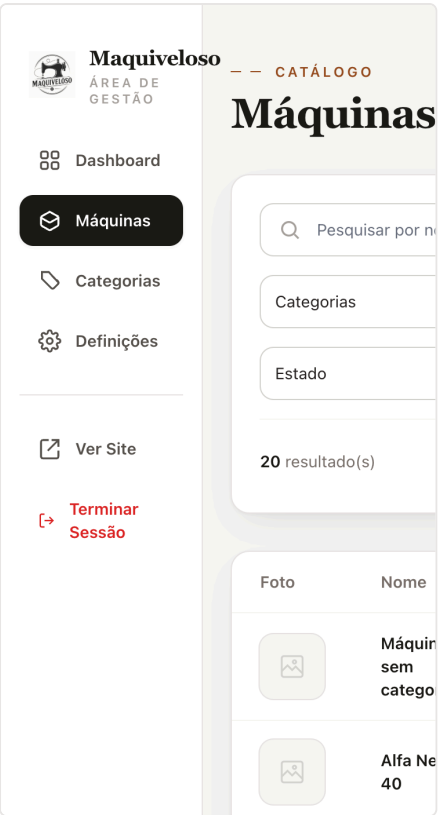


Figura 2 — Lista de máquinas do backoffice a 375 px: a barra lateral ocupa 288 px e a tabela fica cortada (scrollWidth 1156 px).

P1

PERF-001 — Logótipo de 1,17 MB carregado em todas as páginas

Confiança

Confirmado

Bloqueia deploy

Não

Esforço

1 h

Tarefa

T06

Estado atual	public/images/branding/maquivelosoLogo.png tem 1254×1254 px e 1 167 785 bytes. É mostrado a 40×40 px no cabeçalho e no rodapé e usado como favicon.
Problema	O ficheiro é cerca de 100× maior do que o necessário.
Impacto	Cada página pública transfere ≈2,5 MB na primeira visita, dos quais ≈2,3 MB são o logótipo. O Chrome descarregou-o duas vezes: como imagem e como favicon. O servidor de teste não envia cabeçalhos de cache; em produção com Nginx a segunda transferência pode vir da cache (Não confirmado). Uma página sem fotos pesa tanto como o catálogo com 12 miniaturas.
Evidência	Lista de pedidos de /contacto (2 473 391 bytes no total, com duas linhas de 1 167 785 bytes); metrics.json (imgKB 1140 em páginas sem fotos).
Ficheiros	resources/views/layouts/site.blade.php:8,63,128 ; public/images/branding/maquivelosoLogo.png
Recomendação	- Exportar o logótipo em 80×80 e 160×160 (@2x), WebP ou PNG otimizado, abaixo de 15 KB, e usar srcset . - Criar favicon.ico 32×32 e apple-touch-icon 180×180 (ver SEO-003). - Configurar cache longa para /images e /build no Nginx.

6. Achados P2 e P3

6.1 P2 — primeiras semanas

P2 SEC-002 — Cabeçalhos de segurança ausentes e versão do PHP exposta

Confiança Confirmado **Bloqueia deploy** Não **Esforço** 2-3 h **Tarefa** T08

Estado atual `bootstrap/app.php:14-17` só regista o alias `admin`; não há middleware de cabeçalhos. O exemplo Nginx em `DEPLOYMENT.md §7` não tem `add_header`.

Problema As respostas não trazem HSTS, X-Frame-Options/ `frame-ancestors`, X-Content-Type-Options, Referrer-Policy, Permissions-Policy nem CSP. No ambiente de teste é enviado `X-Powered-By: PHP/8.4.23`; em produção isso depende de `expose_php`.

Impacto

- O backoffice pode ser embebido num iframe (clickjacking de ações como mudar estado ou apagar).
- Sem HSTS, o primeiro acesso pode ser feito em HTTP.
- A versão do PHP fica divulgada.

Evidência `curl -I /` no clone.

Ficheiros `bootstrap/app.php:14-17`; `DEPLOYMENT.md §7` (bloco Nginx, perto da linha 232)

Recomendação

- No Nginx, ou num middleware:
 - `Strict-Transport-Security: max-age=31536000; includeSubDomains`
 - `X-Frame-Options: DENY`
 - `X-Content-Type-Options: nosniff`
 - `Referrer-Policy: strict-origin-when-cross-origin`
 - `Permissions-Policy: camera=(), microphone=(), geolocation=()`
- `expose_php=Off`.
- CSP primeiro em modo report-only (depende de CODE-005).

P2 SEC-003 — Recuperação de password permite enumerar emails e não tem limite por IP

Confiança Confirmado **Bloqueia deploy** Não **Esforço** 1 h **Tarefa** T09

Estado atual `routes/auth.php:26-27` não aplica `throttle` ao POST de forgot-password, e a resposta distingue emails existentes de inexistentes.

Problema Um email inexistente recebe "We can't find a user with that email address."; o do admin recebe "We have emailed your password reset link.". Oito pedidos seguidos foram todos aceites (302). O broker só limita reenvios para o mesmo email (60 s).

Impacto Revela o email do administrador (o único utilizador) e facilita ataques dirigidos ao login. O login tem throttle de 5 tentativas (Breeze).

Evidência Pedidos reais ao clone com as duas mensagens.

Ficheiros `routes/auth.php:26-27`

Recomendação Aplicar `->middleware('throttle:6,1')` ao POST e usar uma mensagem neutra única ("Se o email estiver registado, receberá um link."), em português.

P2 SEC-004 — Fotos originais mantêm EXIF (incluindo GPS) e são públicas**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** ≈2 h (dentro de T10) **Tarefa** T10

Estado atual	O upload guarda o ficheiro tal como chega (<code>MachineController.php:140</code>). O original é servido no detalhe e na lightbox. A miniatura GD já não tem EXIF (mitigação parcial).
Problema	Coordenadas GPS, modelo do telemóvel e data ficam públicos no original.
Impacto	Fotos tiradas em casa ou na oficina revelam a localização exata. Requer validação jurídica (RGPD) caso apareçam dados de terceiros.
Evidência	<code>gps.jpg</code> com GPS 41°33'N 8°25'W foi carregado; o ficheiro em <code>storage</code> tem o mesmo sha1 do enviado e é servido pelo URL público.
Ficheiros	<code>app/Http/Controllers/Admin/MachineController.php:140</code> ; <code>resources/views/site/machine-show.blade.php:52-61,176</code>
Recomendação	Depois de aplicar a orientação (FUNC-001), recodificar o original ao guardar sem EXIF, ou gerar um derivado "large" sem EXIF e deixar de servir o original (ver PERF-002). Reprocessar as fotos existentes.

P2 SEC-005 — Livewire instalado sem uso, com rotas e script expostos**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 0,5 h **Tarefa** T01

Estado atual	<code>composer.json:12</code> inclui <code>livewire/livewire ^4.0</code> , mas não há nenhum componente. O <code>route:list</code> mostra as rotas da Livewire (<code>update</code> , <code>upload-file</code> , <code>preview-file</code> , <code>livewire.js</code>). O <code>livewire.js</code> (514 797 bytes) é servido publicamente, e a v4.0.2 tem um advisory medium.
Impacto	Superfície de ataque e de manutenção sem qualquer benefício.
Ficheiros	<code>composer.json:12</code>
Recomendação	<code>composer remove livewire/livewire</code> , correr os testes e fazer commit do lock.

P2 FUNC-003 — Imagens de alta resolução esgotam a memória e deixam estado parcial**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 3-4 h **Tarefa** T10

Estado atual	O <code>ThumbnailService</code> descodifica a imagem inteira sem verificar o número de píxeis. O <code>store()</code> cria a máquina e depois as imagens, sem transação nem limpeza em caso de erro.
Problema	Com <code>memory_limit</code> 128M, um JPEG de 8000×6000 (48 MP, 0,79 MB, dentro do limite de 5 MB) provoca "Allowed memory size of 134217728 bytes exhausted". É um erro fatal, que não se consegue capturar.
Impacto	- O dono vê HTTP 500 com a página vazia. - A máquina fica criada sem imagem e o original fica órfão em <code>storage/app/public/machines</code>. - É provável que o dono repita o envio e crie duplicados. - Picos de memória: 22 MB de base, 120 MB com 24 MP (perto do limite), 214 MB com 48 MP.
Evidência	Upload real no clone (máquina sem imagem, ficheiro órfão <code>2XuLiQHlYc7Y8d3950G21g7LxP8LyD17aB2I79m9.jpg</code>); erro reproduzido via tinkr.

Ficheiros	<code>app/Services/ThumbnailService.php:43-74 ;</code> <code>app/Http/Controllers/Admin/MachineController.php:62-71,126-150,100-111</code>
Recomendação	- Validar <code>dimensions:max_width=8000,max_height=8000</code> no pedido. - No serviço, não gerar a miniatura quando <code>w*h*5 > memória livre</code> (via <code>ini_get('memory_limit')</code>). - Pôr <code>memory_limit=256M</code> no servidor (DEPLOY-001). - Criar a máquina e as imagens numa transação e apagar os ficheiros já gravados se houver exceção.

P2 FUNC-004 — Marca e modelo sem campos no backoffice; pesquisa pública só por nome

Confiança Confirmado **Bloqueia deploy** Não **Esforço** 2-3 h **Tarefa** T11

Estado atual	As colunas <code>brand</code> e <code>model</code> existem; a validação aceita-as (<code>MachineController.php:168-169</code>) e a pesquisa do backoffice usa-as (:36-38). Mas <code>_form.blade.php</code> não tem esses campos e a pesquisa pública usa só <code>name</code> (<code>Site/CatalogController.php:53</code>).
Impacto	Não é possível preencher a marca, o atributo que o cliente mais procura (Singer, Brother...). Pesquisar "Brother" só funciona se a marca estiver no nome.
Ficheiros	<code>resources/views/admin/machines/_form.blade.php ;</code> <code>app/Http/Controllers/Site/CatalogController.php:53 ;</code> <code>resources/views/site/machine-show.blade.php</code> (especificações)
Recomendação	Adicionar os campos marca e modelo ao formulário, mostrá-los nas especificações do detalhe e pesquisar em name/brand/model no site. Filtro por marca opcional.

P2 FUNC-005 — Apagar máquina só existe numa página a que nenhum link leva

Confiança Confirmado **Bloqueia deploy** Não **Esforço** 1 h **Tarefa** T11

Estado atual	O botão Apagar só existe em <code>admin/machines/show.blade.php:23</code> . A lista só tem link para editar (<code>index.blade.php:190</code>) e nenhuma página liga à show.
Impacto	Para apagar, o dono tem de escrever o URL <code>/admin/machines/{id}</code> . Na prática usa "inativo" e acumula registos e ficheiros.
Ficheiros	<code>resources/views/admin/machines/index.blade.php:190 ;</code> <code>resources/views/admin/machines/_form.blade.php ;</code> <code>resources/views/admin/machines/show.blade.php:23</code>
Recomendação	Ação "Apagar" com confirmação na lista e no formulário de edição, ou ligar a página show.

P2 FUNC-006 — Preço arredondado às unidades e preço 0 mostrado como "0 €"

Confiança Confirmado **Bloqueia deploy** Não **Esforço** 1 h **Tarefa** T12

Estado atual	<code>Machine.php:75</code> usa <code>number_format((float) \$this->price, 0, ',', '.') . ' €'</code> .
Problema	O preço 1234,56 aparece como "1.235 €" no cartão e no detalhe (máquina 6). O preço 0 aparece como "0 €" (máquina Janome).

Impacto	O preço mostrado difere do registado (+0,44 €). A indicação de preços ao consumidor tem de corresponder ao preço praticado, incluindo a menção a IVA: Requer validação jurídica. "0 €" sugere uma oferta.
Ficheiros	<code>app/Models/Machine.php:69-76</code>
Recomendação	Mostrar 2 casas decimais quando houver cêntimos e nenhuma quando o valor é inteiro. Tratar <code>price <= 0</code> como "Sob consulta", ou validar <code>gt:0</code> . Criar teste de view (TEST-002).

P2 FUNC-007 — Número de WhatsApp sem validação de formato internacional

Confiança Confirmado (código); Provável (comportamento do wa.me sem indicativo) **Bloqueia deploy** Não

Esforço 1-2 h **Tarefa** T13

Estado atual	<code>SettingsController.php:39</code> só valida <code>nullable string max:50</code> . O componente <code>whatsapp-button.blade.php:8-11</code> tira os não-dígitos e gera <code>wa.me/{dígitos}</code> . A página de contacto mostra os dígitos crus ("351912345678").
Problema	Se o dono escrever "912 345 678" sem o 351, todos os botões "Contactar no WhatsApp" (a conversão principal) apontam para um número inválido, sem aviso.
Ficheiros	<code>app/Http/Controllers/Admin/SettingsController.php:39</code> ; <code>resources/views/components/whatsapp-button.blade.php:8-11</code> ; <code>resources/views/site/contact.blade.php</code>
Recomendação	- Depois de limpar o número, validar <code>^\d{11,15}\$</code> e exigir indicativo, ou prefixar 351 quando tiver 9 dígitos começados por 9. - Mostrar o número formatado ("+351 912 345 678"). - Pré-visualizar o link no backoffice.

P2 FUNC-008 — Informação legal obrigatória em falta (Requer validação jurídica)

Confiança Provável **Bloqueia deploy** Precisa de confirmação (jurídica) **Esforço** 0,5 dia técnico, mais validação

Tarefa T14

Estado atual	Não existe política de privacidade, termos, link para o Livro de Reclamações Eletrónico, informação sobre entidades de Resolução Alternativa de Litígios (RAL), nem denominação social ou NIF. O rodapé só tem contactos.
Impacto	Risco de incumprimento para um site comercial dirigido a consumidores em Portugal: DL 156/2005, alterado pelo DL 74/2017 (Livro de Reclamações Eletrónico); Lei 144/2015 (RAL); RGPD art. 13.º. Requer validação jurídica.
Ficheiros	<code>resources/views/layouts/site.blade.php</code> (rodapé); <code>routes/web.php</code>
Recomendação	Criar as páginas <code>/privacidade</code> e <code>/informacao-legal</code> e pôr no rodapé links para <code>livroreclamacoes.pt</code> e para a entidade RAL, mais a identificação da empresa. Os textos devem ser validados por um jurista.

P2 UI-002 — Conteúdo principal invisível sem JavaScript

Confiança Confirmado **Bloqueia deploy** Não **Esforço** 1 h **Tarefa** T15

Estado atual	<code>resources/css/app.css:61–65</code> aplica <code>opacity:0</code> a <code>[data-reveal]</code> sempre; só o JS (<code>resources/js/app.js:14–40</code>) adiciona <code>.is-visible</code> . O comentário em <code>app.js:11–12</code> fala de progressive enhancement, mas o CSS não degrada.
Evidência	- Com JavaScript desativado ficam invisíveis os 11 blocos da página inicial (incluindo os destaques), os 12 cartões do catálogo e os 2 blocos de contactos (figura 3). - Com JS e scroll real aparecem todos (verificado com a roda do rato). - Na impressão da página inicial sem scroll ficam 8 blocos em branco.
Impacto	Se o bundle JS falhar (manifest errado num deploy, bloqueador, rede móvel instável, browser antigo), o catálogo aparece vazio, embora diga "17 resultado(s)".
Ficheiros	<code>resources/css/app.css:61–70</code> ; <code>resources/js/app.js:14–40</code> ; <code>resources/views/layouts/site.blade.php:2</code>
Recomendação	Esconder só quando há JS. Pôr <code>class="no-js"</code> no <code><html></code> , com um script inline no <code><head></code> a trocá-la por <code>js</code> , e usar o seletor <code>.js [data-reveal]</code> . Alternativa: <code>@media (scripting: enabled)</code> . Manter o <code>reduced-motion</code> .

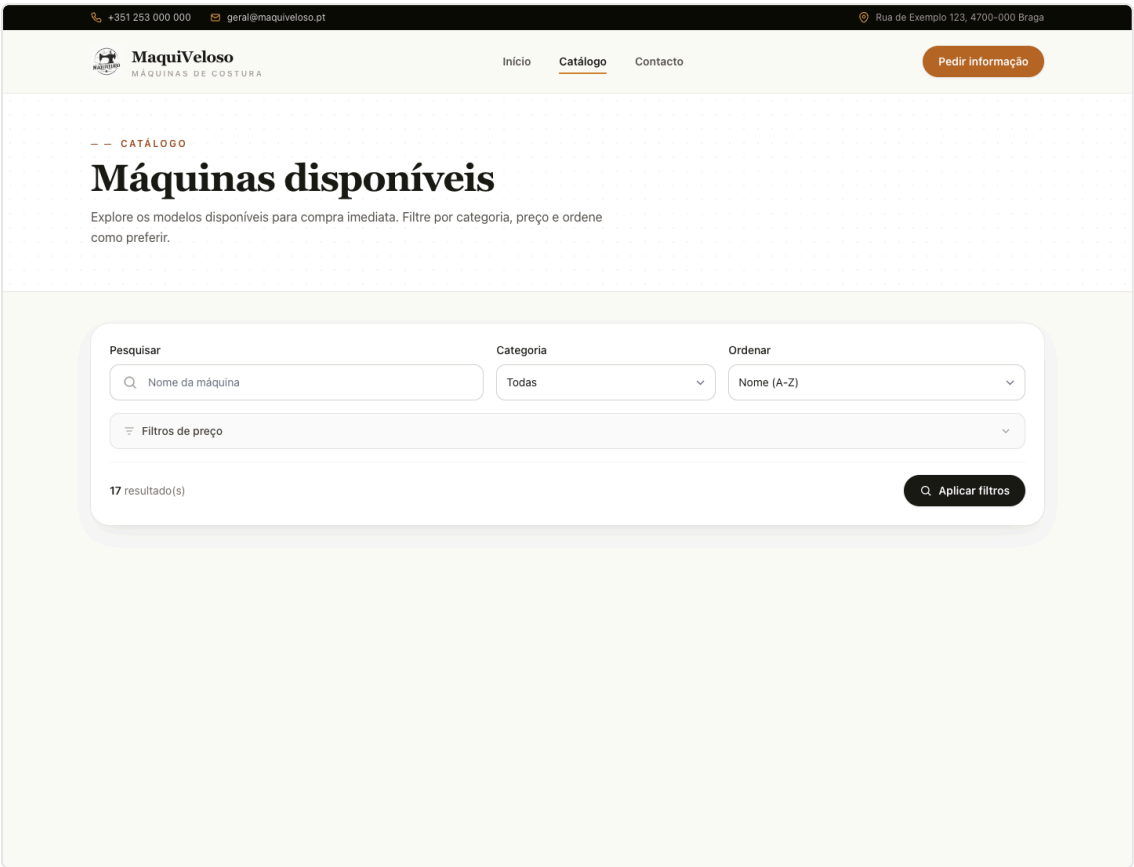


Figura 3 — Catálogo a 1440 px com JavaScript desativado: indica "17 resultado(s)", mas a grelha fica em branco.

P2 UI-003 — Interface parcialmente em inglês e páginas de erro por omissão**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 0,5 dia **Tarefa** T16

Estado atual	<code>.env.production.example:17</code> e <code>config/app.php:81</code> usam <code>APP_LOCALE=en</code> e não há ficheiros <code>lang/pt</code> . <code>layouts/admin.blade.php:3</code> usa o locale, o que dá <code>lang="en"</code> . Não existem views em <code>resources/views/errors</code> .
Evidência	- Login e forgot-password em inglês ("Forgot your password?", "We have emailed..."). - Mensagens de validação e paginação em inglês ("Showing 1 to 12 of 17 results", "« Previous"). - Os erros 404, 403 e 500 usam a página por omissão, em inglês e sem o layout do site. Por exemplo, a máquina vendida <code>/catalogo/22</code> mostra "404 Not Found".
Impacto	Tira confiança a um site todo em português. Os erros de validação do backoffice ficam em inglês e o leitor de ecrã lê o backoffice com pronúncia inglesa.
Ficheiros	<code>.env.production.example:17</code> ; <code>config/app.php:81</code> ; <code>resources/views/layouts/admin.blade.php:3</code> ; <code>resources/views/auth/*</code>
Recomendação	<code>APP_LOCALE=pt_PT</code> e <code>APP_FALLBACK_LOCALE=pt_PT</code>. <code>php artisan lang:publish</code> e tradução pt. - Criar <code>resources/views/errors/{404,403,419,500,503}.blade.php</code> com o layout do site e link para o catálogo. - Publicar e traduzir as views de paginação.

P2 PERF-002 — O detalhe serve o original (vários MB) como imagem principal**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 2–3 h **Tarefa** T10

Estado atual	<code>machine-show.blade.php:52–61</code> usa o URL do original. Só as listagens usam miniaturas.
Evidência	<code>/catalogo/6</code> transfere 6,76 MB, dos quais 5,45 MB em imagens. O original de 4032×3024 (≈4,2 MB) é mostrado com no máximo ≈700 px de largura.
Impacto	Carregamento lento em rede móvel e consumo de dados do cliente. O LCP real em 4G não foi medido (Não confirmado).
Ficheiros	<code>resources/views/site/machine-show.blade.php:52–61,176</code> ; <code>app/Services/ThumbnailService.php</code>
Recomendação	Gerar um derivado "large" (1600 px, q80, sem EXIF) no <code>ThumbnailService</code> e usá-lo no detalhe e na lightbox, com <code>srcset</code> (600w/1600w). Não voltar a servir o original.

P2 A11Y-001 — Campos do backoffice sem rótulo associado**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 2 h **Tarefa** T17

Estado atual	- Em <code>_form.blade.php:152–187</code> os <code><label></code> não têm <code>for</code>. - Os selects de filtro da lista (<code>index.blade.php:60,78</code>) não têm label. - O select de estado (<code>:213–214</code>) é invisível e não tem nome acessível. - O input de renomear categoria não tem label.
Evidência	Axe <code>select-name</code> (critical, x2) na lista, criar e editar; <code>label</code> (critical, x5) nas categorias.
Impacto	O leitor de ecrã anuncia os campos sem nome, e tocar no rótulo não foca o campo.

Ficheiros	<code>resources/views/admin/machines/_form.blade.php:152-187 ;</code> <code>resources/views/admin/machines/index.blade.php:60,78,213 ;</code> <code>resources/views/admin/categories/index.blade.php</code>
Recomendação	Pares <code>for / id</code> em todos os campos, <code>aria-label</code> nos filtros e no seletor de estado, e <code><label class="sr-only"></code> no campo da categoria.

P2 A11Y-002 — Lightbox e galeria sem gestão de foco nem estado	
Confiança	Confirmado (código) Bloqueia deploy Não Esforço 2 h Tarefa T17
Estado atual	O diálogo (<code>machine-show.blade.php:172-177</code>) tem <code>role="dialog"</code> e <code>aria-modal</code> , mas o JS (<code>:208-228</code>) abre e fecha sem mover o foco, sem o prender e sem o devolver. Todas as miniaturas (<code>:85-91</code>) têm o mesmo <code>aria-label="Ver imagem adicional"</code> e a seleção só é visual.
Impacto	Quem usa teclado abre a imagem e o Tab continua a percorrer a página escondida atrás do overlay. Ao fechar, perde a posição. O leitor de ecrã não distingue as miniaturas.
Ficheiros	<code>resources/views/site/machine-show.blade.php:85-91,172-177,208-228</code>
Recomendação	Usar <code><dialog></code> nativo com <code>showModal()</code> , ou, na implementação atual, focar o botão Fechar ao abrir, prender o Tab e devolver o foco ao trigger ao fechar. Nas miniaturas, <code>aria-label="Ver imagem 2 de 5"</code> e <code>aria-pressed / aria-current</code> na ativa.

P2

A11Y-003 — Contraste insuficiente, incluindo o CTA principal

Confiança

Confirmado

Bloqueia deploy

Não

Esforço

1 h

Tarefa

T17

Evidência

(axe color-contrast, serious; o mínimo AA para este texto é 4,5:1)

Elemento	Cores	Contraste	Onde
Botões "Contactar no WhatsApp" / enviar	branco sobre emerald-600, 14 px	3,76:1	detalhe e contacto
Selo "Negociável"	branco sobre #b56824, 12 px	4,22:1	cartões do catálogo
Tagline "MÁQUINAS DE COSTURA"	stone-400 sobre stone-50, 10 px	2,41:1	cabeçalho do site
Textos do backoffice	stone-400 sobre branco, 11–12 px	2,52:1	rodapé da barra e rótulos de secção

Impacto

O CTA de conversão falha AA, e o texto pequeno fica difícil de ler ao sol no telemóvel.

Ficheiros

resources/views/site/machine-show.blade.php:125 ;

resources/views/site/contact.blade.php:135 ;

resources/views/components/ui/badge.blade.php (variante solid);

resources/views/layouts/site.blade.php:67 ;

resources/views/layouts/admin.blade.php:98

Recomendação

Emerald-700 nos botões (≈5,5:1), brand-700 no selo, stone-500 ou stone-600 nos textos pequenos.

P2 SEO-001 — Título igual em todas as páginas e sem metadados de partilha**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 2–3 h **Tarefa** T18

Estado atual	<code>layouts/site.blade.php:7</code> tem <code><title></code> fixo com o nome do negócio. Não há meta description, canonical, Open Graph nem Twitter Card.
Evidência	<code>metrics.json</code> : <code>title "MaquiVelooso"</code> em todas as páginas; <code>metaDesc null</code> ; <code>og 0</code> ; <code>canonical null</code> .
Impacto	Os resultados no Google não se distinguem entre si, e as partilhas no WhatsApp e Facebook (o canal de vendas) aparecem sem foto nem descrição da máquina.
Ficheiros	<code>resources/views/layouts/site.blade.php:7</code> ; <code>resources/views/site/*.blade.php</code>
Recomendação	<code>@yield('title')</code> com o formato <code>"{Máquina} MaquiVelooso"</code>. <code>@yield('meta_description')</code> com os primeiros 155 caracteres da descrição. <code>og:title</code>, <code>og:description</code>, <code>og:image</code> (derivado da foto principal) e <code>og:type=product</code>. - Canonical sem query string de filtros.

6.2 P3 — melhorias**P3 SEC-006 — AdminUserSeeder protegido por lista de exclusão****Confiança** Confirmado (código) **Bloqueia deploy** Não **Esforço** 0,25 h **Tarefa** T20

Estado atual	<code>AdminUserSeeder.php:21</code> só aborta em <code>environment('production')</code> . O <code>DatabaseSeeder.php:23</code> usa uma lista de inclusão (<code>['local', 'testing']</code>).
Impacto	<code>db:seed --class=AdminUserSeeder</code> num ambiente <code>staging</code> cria <code>admin@maquiveloso.com</code> com a password "password".
Ficheiros	<code>database/seeds/AdminUserSeeder.php:21</code>
Recomendação	<code>if (! app()->environment(['local', 'testing'])) return;</code> e um teste para <code>staging</code> .

P3 SEC-007 — Vulnerabilidades npm em dependências de desenvolvimento**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 0,5 h **Tarefa** T01

Estado atual	<code>npm audit</code> encontra 10 vulnerabilidades: 2 critical (<code>concurrently</code> → <code>shell-quote</code>), 6 high (<code>vite</code> , <code>rollup</code> , <code>postcss</code> , <code>picomatch</code> , <code>nanoid</code> , <code>browserslist</code>), 1 moderate e 1 low. Todas têm correção disponível. <code>npm audit --omit=dev</code> dá 0.
Impacto	Nada disto chega à produção (<code>public/build</code> é estático). O risco limita-se à máquina de desenvolvimento e ao CI.
Ficheiros	<code>package.json</code> ; <code>package-lock.json</code>
Recomendação	<code>npm audit fix</code> , depois <code>npm run build</code> e os testes.

P3 FUNC-009 — Remover categoria não diz quantas máquinas ficam sem categoria**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 1 h **Tarefa** T21

Estado atual	O <code>confirm()</code> pergunta só "Remover esta categoria?" (<code>categories/index.blade.php:94-95</code>). A FK tem <code>nullOnDelete</code> (<code>create_machines_table.php:14-17</code>) e a lista não mostra contagens.
Impacto	As máquinas passam sem aviso a "sem categoria" e deixam de aparecer no filtro por categoria.
Ficheiros	<code>app/Http/Controllers/Admin/CategoryController.php:50-56</code> ; <code>resources/views/admin/categories/index.blade.php:94-95</code>
Recomendação	Usar <code>withCount('machines')</code> , mostrar a contagem na lista e na confirmação, ou impedir a remoção de categorias com máquinas.

P3 FUNC-010 — Ordenação do catálogo depende de JavaScript**Confiança** Confirmado (código) **Bloqueia deploy** Não **Esforço** 1 h **Tarefa** T15

Estado atual	O <code>select sort_option</code> (<code>catalog.blade.php:83-90</code>) não tem <code>name</code> ; os campos escondidos <code>sort</code> e <code>dir</code> (<code>:91-92</code>) são preenchidos por JS.
Impacto	Sem JS, "Aplicar filtros" ignora a ordenação escolhida.
Ficheiros	<code>resources/views/site/catalog.blade.php:83-92</code> ; <code>app/Http/Controllers/Site/CatalogController.php</code>
Recomendação	Dar <code>name="sort"</code> ao <code>select</code> com valores compostos (<code>price_asc</code> , ...) e interpretá-los no controller.

P3 FUNC-011 — Sem limite total de imagens por máquina**Confiança** Confirmado (código) **Bloqueia deploy** Não **Esforço** 0,5 h **Tarefa** T11

Estado atual	Há <code>images max:8</code> por pedido, mas cada edição pode acrescentar mais sem limite.
Impacto	Galerias muito longas e disco a crescer. Risco baixo, porque só o admin carrega imagens.
Ficheiros	<code>app/Http/Controllers/Admin/MachineController.php:175</code>
Recomendação	Validar que as imagens existentes mais as novas não passam de 12.

P3 FUNC-012 — Validação sem limite superior para preço e descrição**Confiança** Provável (não reproduzido em MariaDB) **Bloqueia deploy** Não **Esforço** 0,25 h **Tarefa** T12

Estado atual	O preço é validado com <code>numeric min:0</code> , sem máximo, e a coluna é <code>decimal(10,2)</code> . A descrição é <code>string</code> sem máximo, numa coluna <code>text</code> .
Impacto	Em MariaDB com strict mode, um preço $\geq 100\,000\,000$ ou uma descrição com mais de 64 KB dá erro SQL (500). O SQLite aceita.
Ficheiros	<code>app/Http/Controllers/Admin/MachineController.php:170-172</code> ; <code>database/migrations/2026_01_21_182517_create_machines_table.php:22,27</code>
Recomendação	Validar <code>max:99999999.99</code> no preço e <code>max:10000</code> na descrição.

P3 FUNC-013 — Máquinas reservadas desaparecem do site e o link partilhado dá 404**Confiança** Confirmado (comportamento); Não confirmado como defeito (pode ser intencional) **Bloqueia deploy** Não**Esforço** 1–2 h **Tarefa** T21

Estado atual	O catálogo filtra <code>status = available</code> (<code>CatalogController.php:52</code>) e o detalhe faz <code>abort_if(status !== 'available', 404) (:78)</code> .
Impacto	Um link partilhado por WhatsApp de uma máquina que passou a reservada abre um 404 em inglês. O site também não mostra vendas feitas.
Ficheiros	<code>app/Http/Controllers/Site/CatalogController.php:52,78</code>
Recomendação	Decisão de produto. Sugestão: mostrar as reservadas com selo "Reservada" e o CTA adaptado; nas vendidas, página com aviso e link para máquinas semelhantes.

P3 FUNC-014 — Datas mostradas em UTC**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 0,5 h **Tarefa** T21

Estado atual	<code>config/app.php:68</code> usa <code>'timezone' => 'UTC'</code> , e a lista do backoffice mostra <code>created_at</code> em <code>d/m/Y</code> (<code>index.blade.php:182</code>).
Impacto	No horário de verão, uma máquina criada entre as 00:00 e a 01:00 aparece com a data do dia anterior.
Ficheiros	<code>config/app.php:68</code> ; <code>resources/views/admin/machines/index.blade.php:182</code>
Recomendação	Converter na apresentação (<code>->timezone('Europe/Lisbon')</code>), ou mudar a <code>timezone</code> da app com o cuidado devido aos dados existentes.

P3 UI-004 — Fotos verticais cortadas no detalhe**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 0,25 h **Tarefa** T10

Estado atual	<code>machine-show.blade.php:51,61</code> põe a imagem num contentor <code>aspect-[4/3]</code> com <code>object-cover</code> .
Evidência	Na foto vertical da máquina 8 ficam cortados $\approx 44\%$ da altura (22 % em cima e 22 % em baixo). A lightbox (<code>object-contain</code> , <code>:176</code>) mostra a foto inteira.
Impacto	Parte da máquina fica escondida na vista principal.
Ficheiros	<code>resources/views/site/machine-show.blade.php:51,61</code>
Recomendação	Usar <code>object-contain</code> com fundo neutro no detalhe e manter <code>cover</code> nos cartões.

P3 UI-005 — Seletor de estado invisível na lista do backoffice**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 1 h **Tarefa** T05

Estado atual	<code>index.blade.php:213–214</code> tem <code><select class="absolute inset-0 h-9 w-9 cursor-pointer opacity-0"></code> sobre um botão de ícone.
Impacto	A mudança rápida de estado não se descobre, e o controlo não mostra o valor atual (ver também A11Y-001).
Ficheiros	<code>resources/views/admin/machines/index.blade.php:205–225</code>

Recomendação Um select visível, ou um menu com o rótulo "Mudar estado", e confirmação visual; a resposta JSON já existe.

P3 UI-006 — Microcopy e marca inconsistentes no backoffice

Confiança Confirmado **Bloqueia deploy** Não **Esforço** 0,5 h **Tarefa** T21

Estado atual

- O backoffice trata por "tu" ("Ainda não tens máquinas. Clica em...", `index.blade.php:230`; "Podes seleccionar várias imagens (Ctrl).", `_form.blade.php:144`) e o site por "você".
- A marca aparece como "Maquíveloso" (`admin.blade.php:22`) e como "MaquiVeloso".
- "(Ctrl)" não se aplica a telemóvel nem a macOS.

Impacto Aspeto pouco cuidado e instruções erradas no telemóvel.

Ficheiros `resources/views/admin/machines/index.blade.php:230`;
`resources/views/admin/machines/_form.blade.php:144`;
`resources/views/layouts/admin.blade.php:22`

Recomendação Escolher um registo e mantê-lo em todo o backoffice, usar "MaquiVeloso" em todo o lado e escrever "Pode seleccionar várias imagens."

P3 UI-007 — Definições: morada e horário numa só linha; perfil sem acesso no menu

Confiança Confirmado **Bloqueia deploy** Não **Esforço** 1 h **Tarefa** T21

Estado atual `admin/settings.blade.php:45,57` usa `input type="text"` para a morada e o horário, e `layouts/admin.blade.php` não tem link para /profile.

Impacto Um horário com várias linhas é difícil de escrever, e o dono não encontra onde mudar a password.

Ficheiros `resources/views/admin/settings.blade.php:45,57`;
`resources/views/layouts/admin.blade.php`

Recomendação Textarea com `nl2br(e())` na apresentação e um link "Perfil e password" no menu.

P3 PERF-003 — Login e perfil carregam fontes externas (fonts.bunny.net)

Confiança Confirmado **Bloqueia deploy** Não **Esforço** 0,5 h **Tarefa** T16

Estado atual `layouts/guest.blade.php:12-13` e `layouts/app.blade.php:11-12` (Breeze) carregam a Figtree de fonts.bunny.net. O site e o backoffice usam fontes do sistema.

Impacto Pedido a um terceiro, que recebe o IP do visitante (Requer validação jurídica; a Bunny está sediada na UE). Bloqueia a renderização e dá um estilo diferente do resto.

Ficheiros `resources/views/layouts/guest.blade.php:12-13`;
`resources/views/layouts/app.blade.php:11-12`

Recomendação Remover os links e usar o stack de sistema do `tailwind.config.js`, idealmente com login e perfil no layout da marca.

P3 A11Y-004 — Lista de contactos com estrutura <dl> inválida**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 0,5 h **Tarefa** T17

Estado atual Em `contact.blade.php:45`, os filhos `<div>` do `<dl>` contêm um `<span>` (ícone) e outro `<div>` com `dt/dd`.

Evidência Axe `definition-list` (1) e `dlitem` (10), serious.

Ficheiros `resources/views/site/contact.blade.php:45-100`

Recomendação Cada `<div>` do `dl` só com `dt/dd` (o ícone dentro do `dt`), ou trocar por `<ul>`.

P3 A11Y-005 — Hierarquia de cabeçalhos e marcos incompleta**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 1 h **Tarefa** T17

Evidência (axe)

- `heading-order`: h3 sem h2 anterior nos cartões de valor (`home.blade.php:91`) e nos cartões do catálogo.
- Login sem h1 e sem `<main>` (`layouts/guest.blade.php`).
- Perfil sem h1; o botão do menu mobile não tem nome (`layouts/navigation.blade.php:56`).
- Paginação com `aria-label` num `<span>` (`aria-prohibited-attr`).

Ficheiros `resources/views/site/home.blade.php:91`;
`resources/views/components/machine/card.blade.php:39`;
`resources/views/layouts/guest.blade.php`;
`resources/views/layouts/navigation.blade.php:56`

Recomendação Acertar os níveis, pôr h1 e `<main>` nas views do Breeze, `aria-label` no botão do menu e publicar as views de paginação.

P3 A11Y-006 — Alvos de toque pequenos**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 0,5 h **Tarefa** T17

Evidência

- Links da barra superior (telefone e email): 20 px de altura.
- Breadcrumb: 17 px.
- Número de WhatsApp na página de contacto: 17 px.
- "Forgot your password?": 20 px.
- Checkbox "Remember me": 16×16 px.
- Por página pública há 3 a 12 alvos com menos de 24 px.

Impacto A WCAG 2.2 (2.5.8, AA) pede 24×24 px ou espaçamento equivalente. Os links dentro de frases estão isentos; os da barra superior não.

Ficheiros `resources/views/layouts/site.blade.php` (barra superior, rodapé);
`resources/views/site/machine-show.blade.php` (breadcrumb);
`resources/views/auth/login.blade.php`

Recomendação `py-1.5` ou `min-h-6` nos links isolados e checkbox de 20 px com label clicável.

P3 CODE-001 — BOM UTF-8 em duas views**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 0,25 h **Tarefa** T20

Estado atual	<code>resources/views/site/home.blade.php:1</code> e <code>resources/views/site/contact.blade.php:1</code> começam por EF BB BF, e as respostas de <code>/</code> e <code>/contacto</code> também. O README exige "UTF-8 without BOM".
Impacto	Nenhum efeito visual verificado (o Chrome renderiza em CSS1Compat e UTF-8), mas viola a regra do projeto.
Ficheiros	<code>resources/views/site/home.blade.php:1</code> ; <code>resources/views/site/contact.blade.php:1</code>
Recomendação	Regravar os dois ficheiros sem BOM e acrescentar ao CI uma verificação (<code>grep -rl \$'\xEF\xBB\xBF' resources</code>).

P3 CODE-002 — Página inicial numa closure que engole exceções**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 0,5 h **Tarefa** T20

Estado atual	<code>routes/web.php:23–44</code> chama <code>Schema::hasTable('machines')</code> em cada pedido e tem um <code>catch (\Throwable)</code> que não regista nada.
Impacto	Se a BD falhar, a página inicial mostra "sem destaques" e não fica nada no log. Há uma query extra por pedido.
Ficheiros	<code>routes/web.php:23–44</code>
Recomendação	Mover para um <code>HomeController</code> , retirar o <code>hasTable</code> e deixar a exceção propagar-se (ou chamar <code>report(\$e)</code>).

P3 CODE-003 — As definições gravam chaves legadas duplicadas**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 1 h **Tarefa** T20

Estado atual	<code>SettingsController.php:44–49</code> grava <code>phone</code> , <code>email</code> e <code>location</code> além das chaves <code>contact_*</code> .
Impacto	Duas fontes de verdade que podem divergir.
Ficheiros	<code>app/Http/Controllers/Admin/SettingsController.php:44–49</code>
Recomendação	Passar todas as leituras para <code>contact_*</code> e apagar as chaves legadas com uma migration de dados.

P3 CODE-004 — Restos do skeleton Laravel**Confiança** Confirmado **Bloqueia deploy** Não **Esforço** 1 h **Tarefa** T20

Estado atual	<code>README.md</code> e <code>CHANGELOG.md</code> são os do Laravel, e o <code>composer.json:3</code> tem <code>"name": "laravel/laravel"</code>. - Três workflows do skeleton: <code>issues.yml</code>, <code>pull-requests.yml</code> (com <code>pull_request_target</code>, workflow remoto <code>laravel/.github@main</code> e permissão <code>pull-requests: write</code>) e <code>update-changelog.yml</code>. <code>package.json:11</code> tem <code>@tailwindcss/vite</code>, plugin do Tailwind 4 sem uso (o projeto usa Tailwind 3 via PostCSS). - FQCN inline em <code>CatalogController.php:71</code>.
--------------	---

Impacto	O README não explica o projeto (instalação, <code>admin:create</code> , <code>deploy</code>); há workflows de terceiros a correr sem necessidade; há dependências mortas.
Ficheiros	<code>README.md</code> ; <code>CHANGELOG.md</code> ; <code>composer.json:3</code> ; <code>.github/workflows/{issues,pull-requests,update-changelog}.yaml</code> ; <code>package.json:11</code> ; <code>app/Http/Controllers/Site/CatalogController.php:71</code>
Recomendação	• README próprio, com link para <code>DEPLOYMENT.md</code>. • Apagar o <code>CHANGELOG</code> e os três workflows. • Mudar o nome do pacote. • <code>npm remove @tailwindcss/vite</code>. • Usar <code>use App\Models\Category</code>.

P3 CODE-005 — JavaScript inline nas views

Confiança Confirmado **Bloqueia deploy** Não **Esforço** 2 h **Tarefa** T08

Estado atual	Há <code><script></code> inline em <code>site/machine-show.blade.php</code> (galeria e lightbox, linhas 181-230), <code>site/catalog.blade.php</code> , <code>site/contact.blade.php</code> , <code>admin/machines/index.blade.php</code> e <code>admin/machines/_form.blade.php</code> .
Impacto	Impede uma CSP sem <code>'unsafe-inline'</code> (SEC-002), e este código fica fora do Vite (sem minificação nem cache).
Ficheiros	Os cinco acima
Recomendação	Passar o código para módulos em <code>resources/js</code> , inicializados por atributos <code>data-*</code> .

P3 DB-001 — Compatibilidade com MariaDB não verificada nesta versão

Confiança Não confirmado **Bloqueia deploy** Precisa de confirmação **Esforço** 2 h **Tarefa** T07

Estado atual	A produção prevê MySQL/MariaDB (<code>DB_CONNECTION=mysql</code>) e os testes correm em SQLite. A ronda anterior (41f699d) validou as migrations em MariaDB. Nesta ronda o Docker não estava disponível. A única migration nova (<code>2026_06_14_120000_add_thumb_path_to_machine_images_table.php</code>) acrescenta uma coluna string nullable.
Impacto	Risco baixo. O enum de estado e o decimal comportam-se de forma diferente consoante o motor (ver FUNC-012).
Ficheiros	<code>database/migrations/*</code> ; <code>.env.production.example</code>
Recomendação	Ensaio em staging com MariaDB: <code>migrate --force</code> , <code>admin:create</code> , upload de fotos e <code>machines:generate-thumbnails</code> .

P3 TEST-001 — Os testes dependem do build Vite em local

Confiança Confirmado **Bloqueia deploy** Não **Esforço** 0,25 h **Tarefa** T19

Estado atual	<code>tests/TestCase.php</code> não chama <code>withoutVite()</code> . Sem <code>public/build</code> , falham 27 testes (<code>ViteManifestNotFoundException</code>). O <code>tests.yml</code> faz <code>npm run build</code> antes, por isso o CI não é afetado.
Impacto	<code>php artisan test</code> num clone novo falha e confunde quem contribui.

Ficheiros `tests/TestCase.php`

Recomendação `$this->withoutVite()` no `setUp()` do `TestCase`, ou documentar no README.

P3 TEST-002 — Os testes não cobrem os riscos encontrados

Confiança Confirmado **Bloqueia deploy** Não **Esforço** 0,5 dia **Tarefa** T19

Estado atual 98 testes passam. Não há testes para:

- orientação EXIF;
- imagens muito grandes;
- entrega do email de reposição;
- os 4 casos de preço renderizados nas views (o `MachinePricePresentationTest` só testa o modelo);
- conteúdo visível sem JS;
- formato do WhatsApp.

Impacto FUNC-001, FUNC-003 e FUNC-006 passaram com a suite verde.

Ficheiros `tests/Feature/*`; `tests/Unit/*`

Recomendação

- Testes de feature a `/catalogo` e `/catalogo/{id}` que verifiquem "1.234,56 €", "Preço negociável", "Sob consulta" e o selo "Negociável".
- Teste do `ThumbnailService` com uma fixture `Orientation=6`.
- Teste do limite de píxeis.
- `Notification::fake()` para o `ResetPassword`.

P3 SEO-002 — Sem sitemap.xml

Confiança Confirmado **Bloqueia deploy** Não **Esforço** 1 h **Tarefa** T18

Estado atual `public/robots.txt` permite tudo e não tem `Sitemap:`; não existe sitemap.

Ficheiros `public/robots.txt`; `routes/web.php`

Recomendação Rota `/sitemap.xml` com a página inicial, catálogo, contacto e máquinas disponíveis (com `lastmod`), linha `Sitemap:` no `robots.txt` e registo no Google Search Console.

P3 SEO-003 — favicon.ico vazio e ícones em falta

Confiança Confirmado **Bloqueia deploy** Não **Esforço** incluído em T06 **Tarefa** T06

Estado atual `public/favicon.ico` tem 0 bytes. O único ícone é o PNG de 1,17 MB (`site.blade.php:8`). Não há `apple-touch-icon` nem manifest.

Impacto Quem pede `/favicon.ico` (crawlers, alguns browsers, separadores do backoffice e do login) recebe um ficheiro vazio.

Ficheiros `public/favicon.ico`; `resources/views/layouts/site.blade.php:8`;
`resources/views/layouts/admin.blade.php`

Recomendação `favicon.ico` 32×32, PNG 192 e 512, `apple-touch-icon` 180, e ligá-los em todos os layouts.

7. Funcionalidades e lógica

Funcionalidade	Estado	Testes	Notas
Página inicial com hero e destaques	Implementado	Sim	Destaques em featured=true + available (máx. 6); UI-002
Catálogo: pesquisa, categoria, preço mín./máx., ordenação, paginação 12	Implementado	Sim	Pesquisa só por nome (FUNC-004); ordenação depende de JS (FUNC-010); paginação em inglês (UI-003)
Detalhe: galeria, lightbox, breadcrumb, especificações, WhatsApp	Implementado	Parcial	A11Y-002, PERF-002, UI-004
Regras de preço (4 casos)	Implementado	Modelo sim, view não	Ver tabela abaixo; FUNC-006
Contacto: dados e formulário que abre o WhatsApp	Implementado	Sim	FUNC-007, A11Y-004
Backoffice: listar, filtrar, criar, editar máquinas	Implementado	Sim	UI-001, A11Y-001
Backoffice: apagar máquina	Parcial	Sim (rota)	Só numa página sem link (FUNC-005)
Marca/modelo	Parcial	Não	Colunas e validação existem; faltam os campos (FUNC-004)
Upload múltiplo + miniaturas GD	Implementado com defeitos	Sim	FUNC-001, FUNC-003, SEC-004

Funcionalidade	Estado	Testes	Notas
Imagem principal	Implementado	Sim (5)	Transação; outra máquina → 404 (testado)
Mudança rápida de estado	Implementado	Sim	Controlo invisível (UI-005)
Categorias CRUD	Implementado	Sim	FUNC-009
Definições de contacto e negócio	Implementado	Sim	FUNC-007, UI-007, CODE-003
Autenticação e área admin (auth + admin)	Implementado	Sim	Login com throttle
Registo público	Desligado	Sim	GET/POST /register → 404
Recuperação de password	Parcial	Sim (Breeze)	Não entrega em produção (FUNC-002); SEC-003
<code>php artisan admin:create</code>	Implementado	Sim (5)	Não repõe a password de um admin existente
<code>php artisan machines:generate-thumbnails --force</code>	Implementado	Sim (6)	Não corrige a orientação
Mensagens flash	Implementado	Sim (4)	<code>role=status / role=alert</code>
Perfil (Breeze)	Implementado	Sim	Em inglês, sem link no menu (UI-007)
Páginas legais	Em falta	—	FUNC-008
Páginas de erro próprias	Em falta	—	UI-003

Regras de preço, verificadas no HTML renderizado:

Caso	Dados	Cartão	Detalhe	Resultado
1. Preço + negociável	1234,56 · negociável (máquina 6)	Selo "Negociável" + "1.235 €"	"1.235 €" + "Valor sujeito a negociação."	Lógica correta; valor arredondado (FUNC-006)
2. Só preço	149 (máquina 5)	"149 €"	"149 €"	Correto
3. Sem preço + negociável	— · negociável (máquina 7)	Selo "Negociável" + "Preço negociável"	"Preço negociável" + "Contacte-nos para uma proposta personalizada."	Correto
4. Sem preço, não negociável	— (máquina 8)	"Sob consulta"	"Sob consulta" + "Contacte-nos para uma proposta personalizada."	Correto
Limite: preço 0	0 (máquina 11)	"0 €"	"0 €"	Incorreto (FUNC-006)

A lógica vive em `Machine::priceState()` (`app/Models/Machine.php:85`) e no componente `x-machine.price` . A normalização da entrada ("1.234,56", "1 234,56") é partilhada pelo backoffice e pelo filtro público através de `app/Support/PriceNormalizer.php` .

8. Segurança

Controlos verificados sem problemas:

- Registo público desligado (`config/auth.php:126` , `REGISTRATION_ENABLED=false`); `/register` responde 404.
- `/admin` protegido por `auth + admin` (`routes/web.php:83` , `EnsureUserIsAdmin`).
- CSRF ativo em todos os formulários (middleware por omissão).
- Upload: um SVG com `onload` e um ficheiro de texto com extensão `.jpg` foram rejeitados pela validação `image` , sem criar registos.
- Bindings com scope: `PATCH feature` e `DELETE` sobre uma imagem de outra máquina → 404.
- Nenhum `{!! !!}` nas views da aplicação; o output Blade é todo escapado.
- Login com throttle (LoginRequest do Breeze).
- Seeders sem efeito em produção (`DatabaseSeeder` com lista de inclusão; `ProductionSafetyTest`).
- `.env` fora do git; sem segredos no histórico; `.claude/` removido do repositório e ignorado.
- Sem `dd()` , `dump()` nem `console.log` no código.
- `.env.production.example` com `APP_DEBUG=false` e `SESSION_SECURE_COOKIE=true` .
- Cookies: `XSRF-TOKEN` e sessão (`httponly` , `samesite=lax`).

Achados: SEC-001 (P1), SEC-002, SEC-003, SEC-004, SEC-005 (P2), SEC-006, SEC-007 (P3). Com impacto de segurança há também FUNC-002 (recuperação de acesso) e CODE-005 (bloqueia a CSP).

8.1 Dependências

Ecosistema	Âmbito	Resultado	Ação
Composer	produção (<code>--no-dev</code>)	41 advisories em 14 pacotes: 12 high, 25 medium, 3 low, 1 sem severidade	<code>composer update</code> resolve dentro das constraints (SEC-001)
Composer	total	45 advisories em 16 pacotes: 13 high, 25 medium, 6 low, 1 sem severidade	idem
npm	produção (<code>--omit=dev</code>)	0	—

Ecossistema	Âmbito	Resultado	Ação
npm	total	10: 2 critical, 6 high, 1 moderate, 1 low (todas de dev e com correção disponível)	<code>npm audit fix</code> (SEC-007)

Advisories high em produção, por pacote:

Pacote	Versão instalada	Advisories	Versão alvo
league/commonmark	2.8.0	8	2.10.3
laravel/framework	12.48.1	1 (CRLF na regra email)	12.69.3
symfony/mime	7.4.0	1	7.4.19
guzzlehttp/guzzle	7.10.0	1	7.15.5
symfony/http-kernel	7.4.3	1 (<code>#[IsGranted]</code> com HEAD; atributo não usado pela app)	7.4.20

Pacotes sem uso: `livewire/livewire` (SEC-005) e `@tailwindcss/vite` (CODE-004).

`composer validate --strict`: válido.

9. UI/UX e responsividade

Site público:

- Sem overflow horizontal em 375, 390, 768, 1024 e 1440 px em nenhuma página (página inicial, catálogo, catálogo vazio, detalhe com galeria, detalhe com foto rodada, detalhe sem foto, contacto, 404 e login).
- CLS 0 em todas as combinações.
- Hierarquia visual clara, CTAs visíveis na primeira dobra a 375 px e menu mobile funcional.
- O estado vazio do catálogo é contextual ("sem resultados para...").

Backoffice:

- Não é responsivo (UI-001). Medições de `scrollWidth` na tabela 9.1.
- A 375 e 390 px todas as páginas têm scroll horizontal (exceto o perfil Breeze).
- A 768 e 1024 px só a lista de máquinas transborda (1188 px).
- A 1440 px nenhuma página transborda.

Problemas visuais:

- Miniaturas rodadas (FUNC-001).
- Fotos verticais cortadas no detalhe (UI-004).
- Conteúdo invisível sem JS (UI-002).
- Seletor de estado invisível (UI-005).
- Microcopy do backoffice (UI-006) e definições (UI-007).
- Inglês e páginas de erro por omissão (UI-003).

Método: Playwright com Chrome real. Screenshots de página inteira e da primeira dobra em 5 larguras × 17 páginas. Scroll com a roda do rato para disparar o scroll-reveal.

Nota de método: o scroll programático (`window.scrollTo` em saltos) não dispara o `IntersectionObserver` no Chrome headless. Os screenshots de página inteira tirados assim mostravam secções em branco que não acontecem com scroll real. Esse artefacto não foi contado como defeito; o defeito real está em UI-002.

9.1 Largura da página no backoffice (scrollWidth, px)

Página	375	390	768	1024	1440
Dashboard	419	419	768	1024	1440
Lista de máquinas	1156	1156	1188	1188	1440
Criar / editar máquina	426	426	768	1024	1440
Categorias	554	554	768	1024	1440
Definições	409	409	768	1024	1440
Detalhe (show)	543	543	768	1024	1440
Perfil (Breeze)	375	390	768	1024	1440

Valores a vermelho: maiores do que a largura do ecrã, ou seja, com scroll horizontal.

10. Acessibilidade

- **Bom:**
 - Skip link.
 - `lang="pt"` no site.
 - Menu mobile com `aria-expanded`.
 - Labels no catálogo.
 - `prefers-reduced-motion` respeitado no CSS e no JS.
 - Foco visível nos componentes `x-ui.*`.
 - Flash com `role=status` e `role=alert`.
 - `alt` com o nome da máquina.
 - Lightbox fecha com Esc.
- **Achados:** A11Y-001, A11Y-002, A11Y-003 (P2); A11Y-004, A11Y-005, A11Y-006 (P3).
- **Relacionados:** UI-003 (`lang="en"` no backoffice) e UI-005.
- **Ferramenta:** axe-core 4.13.0 com as regras wcag2a, wcag2aa, wcag21a, wcag21aa, wcag22aa e best-practice, a 375 e 1440 px. Teclado e foco da lightbox verificados por leitura do código.
- **Não verificado:** teste com leitor de ecrã real (VoiceOver/NVDA) — Não confirmado.

11. Performance

Página (primeira visita, sem compressão)	Total	Imagens	Queries SQL
Página inicial	2,51 MB	1,19 MB	14
Catálogo (12 cartões)	2,58–2,67 MB	1,24–1,33 MB	10
Detalhe com 5 fotos	6,76 MB	5,45 MB	7
Detalhe sem foto	2,47 MB	1,17 MB	7
Contacto	2,47 MB	1,17 MB	4

- **Bom:**
 - Miniaturas de 600 px nas listagens.

- `loading="lazy"`, `width` e `height` em `x-ui.image`.
- `fetchpriority="high"` na imagem principal.
- Eager loading (`firstImage` e `featuredImage`), sem N+1.
- Índices em `status`, `category_id`, `price` e `created_at`.
- JS de 16,5 kB e CSS de 11,5 kB (gzip).
- **Achados:** PERF-001 (P1), PERF-002 (P2), PERF-003 (P3); FUNC-003 (memória).
- **Não confirmado:**
 - O LCP real em rede móvel não foi medido (o localhost dá valores sem significado).
 - A compressão e a cache do Nginx de produção não foram observadas.

12. Qualidade de código

Arquitetura: monólito Laravel com Blade, Alpine e Tailwind; área pública e backoffice no mesmo projeto.

Separação de responsabilidades:

- Controllers em `Site/` e `Admin/`.
- Serviço de imagens `app/Services/ThumbnailService.php`, partilhado pelo upload, pela remoção e pelo comando.
- Normalização de preço `app/Support/PriceNormalizer.php`, partilhada pelo backoffice e pelo filtro.
- Estados configuráveis em `config/machines.php`.
- Regra de preço em `Machine::priceState()`.
- Componentes Blade `x-machine.*` e `x-ui.*`.
- Composer de settings nas views `layouts.site` e `site.*`.

Pontos fortes: uma fonte de verdade para as regras de preço, os estados e as miniaturas. Os comandos Artisan cobrem o arranque em produção e o backfill.

Fraquezas:

- Closure na página inicial (CODE-002).
- JS inline (CODE-005).
- Chaves de settings duplicadas (CODE-003).
- Upload sem transação (FUNC-003).
- Restos do skeleton (CODE-004).
- BOM (CODE-001).
- Livewire sem uso (SEC-005).

13. Base de dados

Esquema: 10 migrations.

- Tabelas: `users` (com `is_admin`), `categories`, `machines`, `machine_images` (com `thumb_path` e `is_featured`), `settings`, `sessions`, `cache`, `jobs` e `password_reset_tokens`.
- `machines.category_id` → FK nullable com `nullOnDelete`.
- `status` é um enum (`available`, `reserved`, `sold`, `inactive`).
- `price` é decimal(10,2) nullable.
- Índices em `status`, `category_id`, `price` e `created_at`.

Em produção:

- `SESSION_DRIVER`, `CACHE_STORE` e `QUEUE_CONNECTION` usam a base de dados.

- Os backups estão documentados (mysqldump + `storage/app/public`, `DEPLOYMENT.md` §9), com teste de restauro recomendado.

Achados: DB-001 (MariaDB não reconfirmada), FUNC-012 (limites), FUNC-009 (FK nullOnDelete silenciosa).

Ambiente local do utilizador: a migration `2026_06_14_120000_add_thumb_path_to_machine_images_table` está Pending. Não foi aplicada, porque esta auditoria não altera dados.

14. Testes

- **php artisan test, com build:** 98 passam, 1 ignorado (ramo sem GD), 273 asserções, 2,08 s.
- **Sem public/build:** 27 falham (TEST-001).
- **Suites novas desde a última auditoria:**
 - `ProductionSafetyTest` (4), `MachineThumbnailCommandTest` (6), `MachineMainImageTest` (5).
 - `MachinePricePresentationTest` (5, ao nível do modelo), `AdminMachinePriceTest` (dataProvider).
 - `AdminFlashTest` (4), `AdminCreateCommandTest` (5), `tests/Unit/PriceNormalizerTest`.
- **CI:** `.github/workflows/tests.yml` faz `npm ci`, `npm run build` e `php artisan test` em PHP 8.2, 8.3 e 8.4. O estado das execuções no GitHub não foi consultado (sem `gh CLI`) — Não confirmado.
- **Achados:** TEST-001, TEST-002.

15. SEO e privacidade

- **Bom:**
 - `lang="pt"`.
 - Um h1 por página pública.
 - URLs legíveis (`/catalogo`, `/catalogo/{id}`, `/contacto`).
 - Imagens com `alt`.
 - Sem overflow no mobile.
 - `robots.txt` permissivo.
- **Achados:** SEO-001 (P2), SEO-002, SEO-003 (P3).
- **Relacionados:** FUNC-013 (404 em máquinas reservadas), UI-003 (404 sem navegação) e PERF-001 e PERF-002 (peso das páginas).
- **Recomendado:** URLs com slug (`/catalogo/6-brother-innov-is-f420`) e JSON-LD `Product / LocalBusiness` (ver Missing Features).

15.1 Privacidade e informação legal

Tema	Estado	Referência
EXIF/GPS nas fotos originais públicas	Exposto	SEC-004
Fontes de terceiros (fonts.bunny.net) no login e perfil	Pedido a terceiro	PERF-003 — Requer validação jurídica
Política de privacidade, Livro de Reclamações Eletrónico, RAL, identificação da empresa	Em falta	FUNC-008 — Requer validação jurídica
Cookies	Só XSRF-TOKEN e sessão (estritamente necessários); sem analytics nem scripts de terceiros no site público	Aviso de cookies provavelmente dispensável — Requer validação jurídica

Tema	Estado	Referência
Formulário de contacto	Não guarda dados; abre o WhatsApp no dispositivo do visitante	—
Logs	Em local contêm links de reposição de password (mailer `log`); em produção com <code>LOG_LEVEL=warning</code> não	FUNC-002
Menção "IVA incluído" nos preços	Ausente	FUNC-006 — Requer validação jurídica

16. Deploy readiness

Estados possíveis: Pronto · Precisa de confirmação · Bloqueador.

Item	Estado	Referência / nota
Build de assets (<code>npm ci && npm run build</code>)	Pronto	Build OK; <code>public/build</code> fora do git
Testes	Pronto	98 passam com build
Migrations (SQLite)	Pronto	10 aplicadas no clone
Migrations (MariaDB)	Precisa de confirmação	DB-001
Arranque do admin (<code>admin:create</code>)	Pronto	Seeders bloqueados em produção
Registo desligado	Pronto	<code>/register</code> → 404
<code>.env.production.example</code>	Precisa de confirmação	MAIL (FUNC-002), APP_LOCALE (UI-003), APP_URL
Email / recuperação de password	Precisa de confirmação	FUNC-002 (P1)
Limites de upload PHP/Nginx	Precisa de confirmação	DEPLOY-001 (P1)
Extensões PHP	Precisa de confirmação	GD e fileinfo documentadas; falta <code>exif</code> (FUNC-001)
<code>storage:link</code> e permissões	Pronto	DEPLOYMENT.md §3/§6
HTTPS e cookie seguro	Pronto	DEPLOYMENT.md §8, SESSION_SECURE_COOKIE=true
Cabeçalhos de segurança	Precisa de correção	SEC-002
Dependências	Precisa de correção	SEC-001 (P1)
Backups e rollback	Pronto	§9 e §13 documentados
Filas / cron	Pronto	Não são necessários (o <code>ResetPassword</code> é síncrono)
Miniaturas existentes após a correção EXIF	Precisa de confirmação	Correr <code>machines:generate-thumbnails --force</code> (FUNC-001)
Páginas legais	Precisa de confirmação	FUNC-008
Ordem <code>optimize:clear</code> → <code>migrate</code> numa instalação nova	Pronto	A documentação corre <code>migrate</code> primeiro; com <code>CACHE_STORE=database</code> , <code>optimize:clear</code> antes das migrations falha ("no such table: cache") — não inverter a ordem

Bloqueadores: nenhum.

17. Funcionalidades em falta

17.1 Necessárias

- Informação legal e Livro de Reclamações Eletrónico (FUNC-008, Requer validação jurídica).
- Envio de email transacional, ou reposição de password por CLI (FUNC-002).
- Páginas de erro em português com o layout do site (UI-003).

- Campos marca e modelo no backoffice (FUNC-004).
- Ação de apagar máquina acessível (FUNC-005).

17.2 Recomendadas

- Metadados por página, Open Graph e sitemap (SEO-001, SEO-002).
- Derivado de imagem "large" sem EXIF (PERF-002, SEC-004).
- JSON-LD `Product` e `LocalBusiness`.
- Estado "Reservada" visível no site (FUNC-013).
- Reordenar imagens por arrastar.
- Duplicar máquina.
- Monitorização de erros (Flare, Sentry ou email de alertas) e de uptime sobre `/up`.
- Backups automatizados com teste de restauro periódico.
- Filtro por marca.

17.3 Opcionais

- Formulário de contacto com registo ou envio por email (alternativa ao WhatsApp).
- Analytics sem cookies, como Plausible ou Umami (Requer validação jurídica).
- URLs com slug.
- Formatos WebP/AVIF.
- Vários administradores com papéis diferentes.
- Histórico de alterações de preço e estado.
- Mapa na página de contacto (com cuidado de privacidade).

18. Plano de ação

Cada achado está atribuído a uma única tarefa. As estimativas são de trabalho técnico e não incluem decisões do dono nem validação jurídica.

Fase 1 — Antes do lançamento público (≈3 dias)

Tarefa	Descrição	Achados	Prioridade	Esforço	Depende de
T01	Atualizar dependências PHP e npm; remover Livewire	SEC-001, SEC-005, SEC-007	P1	2–3 h	—
T02	Corrigir a orientação EXIF nas miniaturas e regenerá-las	FUNC-001	P1	2–3 h	—
T03	Recuperação de acesso: SMTP, comando de reposição, documentação	FUNC-002	P1	3–4 h	Decisão SMTP
T04	Configurar e documentar limites de upload (PHP e Nginx)	DEPLOY-001	P1	1–2 h	Dados do alojamento
T05	Backoffice responsivo (layout, lista, seletor de estado)	UI-001, UI-005	P1	1–1,5 dias	—
T06	Logótipo, favicon e ícones otimizados	PERF-001, SEO-003	P1	1 h	—
T07	Ensaio de deploy em staging com MariaDB	DB-001	P3	2 h	T01, T02, T04

Fase 2 — Primeiras semanas (≈5–6 dias)

Tarefa	Descrição	Achados	Prioridade	Esforço	Depende de
T08	Cabeçalhos de segurança; passar os scripts inline para o Vite	SEC-002, CODE-005	P2	4–5 h	—
T09	Throttle e mensagem neutra na recuperação de password	SEC-003	P2	1 h	T03, T16
T10	Pipeline de imagens robusta: limite de píxeis, transação, derivado "large" sem EXIF, <code>object-contains</code>	FUNC-003, PERF-002, SEC-004, UI-004	P2	1 dia	T02
T11	Backoffice: marca e modelo, apagar na lista, limite total de imagens	FUNC-004, FUNC-005, FUNC-011	P2	0,5 dia	T05
T12	Preço: casas decimais, preço 0, limites de validação	FUNC-006, FUNC-012	P2	1,5 h	—
T13	WhatsApp em formato internacional	FUNC-007	P2	1–2 h	—
T14	Páginas e links legais	FUNC-008	P2	0,5 dia + jurista	—
T15	Conteúdo e ordenação funcionais sem JavaScript	UI-002, FUNC-010	P2	2 h	—
T16	Português em toda a app e páginas de erro próprias	UI-003, PERF-003	P2	0,5 dia	—

Tarefa	Descrição	Achados	Prioridade	Esforço	Depende de
T17	Acessibilidade: labels, foco da lightbox, contraste, estrutura, alvos de toque	A11Y-001, A11Y-002, A11Y-003, A11Y-004, A11Y-005, A11Y-006	P2	1 dia	T05, T16
T18	SEO: títulos, meta description, Open Graph, canonical, sitemap	SEO-001, SEO-002	P2	3–4 h	T10 (og:image)

Fase 3 — Manutenção (≈1,5 dias)

Tarefa	Descrição	Achados	Prioridade	Esforço	Depende de
T19	Testes: withoutVite, views de preço, EXIF, imagens grandes, reset de password	TEST-001, TEST-002	P3	0,5 dia	T02, T10, T12, T15
T20	Limpeza: BOM, HomeController, settings legadas, restos do skeleton, seeder com lista de inclusão	CODE-001, CODE-002, CODE-003, CODE-004, SEC-006	P3	3–4 h	T01
T21	Backoffice e produto: categorias, reservadas, fuso horário, microcopy, definições	FUNC-009, FUNC-013, FUNC-014, UI-006, UI-007	P3	0,5 dia	T05

Cobertura: 49 achados em 21 tarefas, cada achado numa só tarefa.

19. Conclusão

Precisa de confirmação

A versão 86bad95 resolveu os três P0 da auditoria anterior e subiu claramente de qualidade: regras de preço centralizadas, miniaturas, deploy documentado, arranque seguro do administrador e um site público sem problemas de layout entre 375 e 1440 px.

Não há bloqueadores técnicos. Antes do lançamento público convém fechar a Fase 1 do plano (T01–T07, ≈3 dias):

- atualizar as dependências e remover a Livewire;
- corrigir a orientação das miniaturas;
- garantir a recuperação de acesso do administrador;
- configurar os limites de upload;
- tornar o backoffice utilizável no telemóvel;
- otimizar o logótipo;
- ensaiar o deploy em MariaDB.

Indicador	Valor
Estado de deploy	Precisa de confirmação
Achados	P0 0 · P1 6 · P2 17 · P3 26 · total 49
Maior risco	Fotos verticais de telemóvel aparecem de lado nas listagens (FUNC-001); com os limites por omissão do PHP e do Nginx, o upload também falha (DEPLOY-001)
Decisões do dono	Fornecedor SMTP · limites de upload e memória do alojamento · validação jurídica da informação legal
Ação local pendente	<code>php artisan migrate</code> (migration <code>add_thumb_path</code> Pending no ambiente local)
Relatório estruturado	<code>docs/audit/MaquiVelooso_Auditoria_Completa.md</code> (mesmos IDs e conclusões)